

How Preston-Check Becomes the Gold Standard

The 3-7 year playbook for canonical fintech-security positioning

Preston-Check Maintainers

2026-05-04

How Preston-Check Becomes the Gold Standard

The thesis

Gold-standard positioning is not won by having the best tool. It is won by being the most embedded in the ecosystem that surrounds it. PCI-DSS, OWASP Top 10, CIS Benchmarks, NIST CSF — none of them are “the best.” They are the ones everyone defers to. Becoming Preston-Check the canonical reference for fintech security is a 3-7 year campaign with very specific moves.

The five stages

Stage 1 — Discovered. People try the tool. Free adoption. Viral mechanics. Today’s launch is this stage. As of v1.7.3 the catalog is at 294 checks across 33 frameworks, the GitHub Releases pipeline is live (`brew install preston-check` and `curl ... install.sh | sh` both work), and the threat-intel cron is committing weekly draft checks to `checks/community/proposed/`.

Stage 2 — Recommended. Practitioners tell each other in Slack channels, Hacker News comments, internal docs. “We use Preston-Check for our pre-deploy security gate.” This emerges naturally from a generous free tier plus quality output. Reach this stage in months 6-12.

Stage 3 — Required. Auditors say “do you have a Preston-Check report?” Compliance platforms (Drata, Vanta, Secureframe) accept Preston-Check evidence. Buyers write it into RFPs. This stage is where revenue compounds — you go from a free tool to a customer-mandated tool. Year 2.

Stage 4 — Cited. Regulators reference Preston-Check in guidance documents. NIST cites it as a reference implementation for the framework controls. OWASP names it the canonical scanner for the Smart Contract Top 10. Annual industry reports (Verizon DBIR, Mandiant M-Trends) cite Preston-Check telemetry. Year 3.

Stage 5 — Embedded. Preston-Check checks become the *de facto* spec. When a new framework like DORA gets implemented, the implementation maps to Preston-Check checks rather than the other way around. Treasury departments adopt it for their own oversight. Universities teach with it. Year 4-6.

The eight moves that drive stage transitions

1. The annual State of Fintech Security report

Highest-leverage single artifact. Verizon's Data Breach Investigations Report (DBIR) became the gold-standard threat intelligence document because they published it every year for 17 years with clean data and good narrative. Preston-Check's anonymized opt-in telemetry becomes the data source. Compile in Q4 each year, publish in February. Free PDF download with email gate. Press releases. Conference talk circuit around its findings. Within 3 annual editions, journalists and regulators cite it as the canonical fintech security benchmark.

Cost: approximately \$30k/year for a writer plus designer once you have data. Impact: the single largest stage-transition lever you have.

The first edition shipped in v1.6.0 as `docs/state-of-fintech-security/2026.md`. It establishes the methodology and template. Subsequent editions become quantitative as telemetry accumulates.

2. Standards-body engagement

The pattern that worked for HashiCorp, Sigstore, and similar: engage early, contribute substantively, become a working-group member, eventually become the reference implementation. Specifically: propose Preston-Check checks be officially adopted by OWASP Smart Contract Top 10, OWASP API Top 10, OWASP Mobile MAS. Submit RFCs. Volunteer to maintain framework-mapping documents. Sponsor working group lunches.

The OWASP Foundation will accept tools that are open source, well-maintained, and have a maintainer willing to do the unglamorous coordination work — most security tool vendors will not. NIST publishes a Cybersecurity Tools page that accepts free submissions from open-source tools meeting the inclusion criteria.

3. Auditor partnerships

The actual inflection point. Stage 3 happens when Big Four or mid-tier audit firms accept Preston-Check evidence packets in their workflow. Specific path: pick one mid-tier firm first (BDO, Crowe, Plante Moran are realistic targets — Big Four is harder), offer free Enterprise licenses for their entire audit team, build a custom evidence template that matches their internal documentation format, hand-hold their first 5-10 engagements. After 6 months they have a “Preston-Check rapid audit prep” service line. After 12 months, your name shows up in their RFP responses.

One firm partnership unlocks 50-200 customer adoptions over 18 months.

4. Compliance platform integrations

Force-multiplier. Drata, Vanta, Secureframe, Tugboat Logic — each pushes Preston-Check evidence directly into their compliance workflows as evidence-of-control. They have approximately 5,000 customers each going through SOC 2 / ISO 27001 / HIPAA prep. Each integration is 4-8 weeks of engineering work and a co-marketing agreement. After the first integration ships, customers of that platform start asking for Preston-Check. After three integrations ship, you are on every modern fintech’s compliance stack by default.

Drata alone could 10x your TAM in year 2.

The integration adapters shipped in v1.6.0 as `tools/integrations/{drata,vanta,secureframe}/`. The next step is submitting them to each platform’s marketplace.

5. Conference speaker circuit

The reputation engine. The Preston X founding story is genuinely compelling and gives you a hook journalists and conference programs find irresistible. Submit talks to: RSA Conference, BlackHat USA, DefCon AppSec Village, OWASP Global AppSec, FS-ISAC Summit, FATF working groups, central bank cyber conferences. Three accepted talks per year for three years gets you to approximately 5,000 in-person practitioner exposures. Recordings live on YouTube indefinitely and rank well in fintech-security searches.

Speaker fees and travel are real costs (around \$15k/year), but the brand-building ROI is unmatched.

6. The “Preston-Check Certified” credential program

Free training plus paid certification exam. People put “Preston-Check Certified Auditor” on LinkedIn. Companies hire for it. Universities include it in fintech-security curricula. The pattern that worked for AWS Certified, CompTIA Security+, CISSP. **In year 2-3, this becomes a self-sustaining ecosystem of practitioners whose careers depend on Preston-Check existing.**

Multi-year compounding effect.

7. Regulator engagement

Small-jurisdiction-first strategy. US and EU regulators are slow and will not engage with new tools. But smaller jurisdictions actively look for ways to upgrade their regulatory tech: Bermuda Monetary Authority, Bahamas Securities Commission, Lithuania Bank, Singapore MAS Innovation Hub, Saudi Central Bank. Offer free Enterprise licenses, host their fintech sandbox programs, get Preston-Check listed as a recommended tool in one of their guidance documents. After two of those, US and EU regulators take you seriously. First regulator citation: 12-18 months. Each subsequent citation: cumulative reinforcement.

8. Open-source positioning

The discoverability engine. Submit Preston-Check to every "awesome-security" GitHub list. Publish on every relevant subreddit (r/devsecops, r/netsec, r/fintech, r/AskNetsec). Pull-request the OWASP project listings. Engage in fintech-security Twitter and LinkedIn discussions. Sponsor relevant OSS projects (sigstore, in-toto, OWASP MASVS). Background ambient work that compounds organic discovery.

What you control and what you do not

You control: product quality, content output, integration velocity, conference submissions, partnership outreach, certification program design, telemetry data collection, annual report production. All execution-side.

You do not control: which regulators pick up references to Preston-Check, which Big Four firm bites first, which conferences accept your talks, which OWASP working groups agree to formalize your suggestions. These require *patience and consistency*, not hustle. The companies that became gold standards (HashiCorp, Snyk, Vercel, MongoDB) all have stories of years of "we tried, nothing happened, kept trying, eventually it tipped."

The single most underrated discipline in becoming a gold standard is **showing up the same way for 5+ years**. Snyk published quarterly vulnerability reports starting in 2017 when they had ~50 paying customers. Most weren't read by anyone for the first 2 years. By year 4 those reports were cited in every JavaScript security article. By year 6 they were the canonical reference. The compounding only works if you keep going through the long stretch where nobody seems to be paying attention. Most companies stop the report at year 2 because it "isn't working." That's exactly when the work starts paying off if you persist.

Commit to the State of Fintech Security report annually for 5 years before evaluating whether it is working.

Realistic timeline and milestones

Year 1 — Discovery and Recommended. 1,000 active free users. First three Drata-class compliance integrations shipped. First conference talk accepted (RSA Innovation Sandbox or BlackHat Briefings). First mid-tier audit firm partnership signed. First annual State of Fintech Security report published with whatever data you have. Brand recognition within fintech-security Twitter. Goal: 50 paying Pro customers, 3 Enterprise.

Year 2 — Required. 10,000 active free users. Big Four partnership conversations active (one signed). State of Fintech Security report v2 published with year-over-year trends, becoming a referenced industry artifact. Preston-Check Certified launched. First regulator citation (small jurisdiction). OWASP working-group participation visible. 250 Pro customers, 15 Enterprise. Sales-led motion has started for Enterprise tier.

Year 3 — Cited. 50,000 active free users. NIST cybersecurity-tools page lists Preston-Check. Annual report cited in 10+ industry publications. Big Four partnership operational. Preston-Check Certified has 1,000+ practitioners on LinkedIn with the credential. Compliance platform integrations now bidirectional. Telemetry data is the largest curated fintech-security dataset publicly cited. 1,000 Pro, 100 Enterprise. Approaching \$20M ARR.

Year 4-6 — Embedded. OWASP, FATF, NIST regularly cite Preston-Check. Universities teach with it. Federal regulators in three jurisdictions use it for their own oversight. Annual report becomes the canonical “what’s the state of fintech security right now” reference. Preston-Check is the obvious answer to “what scanner should we use for fintech compliance?” — competitors have to argue against it rather than for themselves. Brand is now genuinely defensible. \$50M+ ARR with 70% gross margin.

What to NOT chase

Do not chase enterprise sales pipeline before integrations exist. A direct sales motion at \$30k/yr ACV requires 5+ touches to close; a Drata integration brings 50 inbound qualified leads automatically. The latter has 10x the ROI in the first 18 months.

Do not chase Big Four partnerships first. They are slow, political, and will not return your emails until you have customer references they recognize. Mid-tier first (6-month sales cycle), then Big Four (12-18 month cycle).

Do not chase international expansion before US/EU traction. Localization, regulatory variation, and cross-border legal complexity will eat 6 months of engineering for marginal revenue. The US and EU markets alone support a \$1B company.

Do not add features that are not either viral levers or moat builders. Every feature shipped past a quality threshold has opportunity cost. The features to ship: AI auto-fix (✅ shipped v1.7.1, viral), peer-comparison percentiles (moat via data; depends on telemetry volume), Drata integration (channel partner), branded PDF (table-stakes for paid). The features to skip in year 1: SSO (defer until Enterprise demands it), custom on-prem (huge engineering cost), more frameworks (you have 33; quality of curation matters more than count from here).

The headline

The work that makes Preston-Check the gold standard is not building a better scanner — it is **building the ecosystem of auditors, regulators, integrations, and content that makes Preston-Check the only one that *matters***. Five years of consistent investment in the right boring things gets you there. Most competitors will get distracted; consistency wins.